

에듀 세이프 심사 보고서

심사 대상	DevYonghunT/WooDongBae (main)
고정 지점	커밋 ca6c5e6629ec338d0055aef4bef5c2d7f0ea92b7 — 이 심사는 이 제출물에 대한 것이며, 이후 수정하면 지문이 달라져 효력이 없습니다.
루브릭 버전	core-1
기능 프로파일	해당 기능 없음 (공통 기준만 적용) — 적용 심사 항목 15 / 37
보호 수준	L0 공통 기본선 — 모든 앱에 예외 없이 적용되는 최소선
AI 분석 고지	Anthropic API(claude-sonnet-5) 사용 — 데이터 파일 내용 미전송, 비밀키 마스킹 후 전송, 검토 커버리지 93%. AI 판정은 초안이며 근거 미확인 판정은 자동 강등됨.
심사일	2026년 8월 29일

불합격 후보

반드시 수정 2건 · 권장 수정 5건 · 사람 확인 필요 7건

카테고리별 상태 프로필

수집 확인 필요	비밀·파일 필수 미충족	접근·권한 필수 미충족	제3자 전송 확인 필요
코드 안전 미충족	고지·보유·파기 확인 필요		

AI 검토 커버리지 고지

AI가 검토한 파일은 전체의 **93%**입니다. 제외: supabase/feedback_schema.sql(데이터 파일 — 내용 미전송(존재만 고지)), supabase/migrations/001_notification_system.sql(데이터 파일 — 내용 미전송(존재만 고지)), supabase/migrations/002_member_features.sql(데이터 파일 — 내용 미전송(존재만 고지)), supabase/migrations/003_add_indexes.sql(데이터 파일 — 내용 미전송(존재만 고지)), supabase/migrations/004_enhance_rls.sql(데이터 파일 — 내용 미전송(존재만 고지)), supabase/migrations/005_audit_log.sql(데이터 파일 — 내용 미전송(존재만 고지)), supabase/migrations/006_constraints.sql(데이터 파일 — 내용 미전송(존재만 고지)), supabase/schema.sql(데이터 파일 — 내용 미전송(존재만 고지)), package-lock.json(단일 파일이 호출 1회 한도를 초과 — 제외)



판정표

항목	법적 무게	판정	사유·근거
주민등록번호를 수집·보관·처리하지 않는다 R-rrn · 필수 · L0	법률	판단불가	이 코드 묶음에는 주민등록번호 수집·처리 관련 근거가 없어 판단 불가하다.
비밀키(API 키·토큰·개인키)가 코드·저장소에 노출되지 않는다 R-secrets · 필수 · L0	고시·훈령	미충족	공공데이터 API 키(serviceKey)가 포함된 요청 URL 전체가 서버 콘솔 로그로 그대로 출력되어 로그를 통한 비밀키 노출 위험이 있다. app/api/sync/route.ts: const targetUrl = `\${API_URL}?serviceKey=\${apiKey}&numOfRows=\${PAGE_SIZE}&pageNo=\${pageNo}`; app/api/sync/route.ts: console.log(`🐛 호출 URL (page \${pageNo}):`, targetUrl);
DB 쓰기가 전체 공개(allow write: if true 등)로 열려 있지 않다 R-db-locked · 필수 · L0	고시·훈령	판단불가	DB 쓰기 권한 규칙이 정의된 supabase/schema.sql 및 migrations 파일이 이 묶음에 포함되지 않아 확인할 수 없다.
서버 경로(API·관리 기능)가 클라이언트 검사에만 의존하지 않고 서버에서 인증을 검사한다 R-server-guard · 필수	고시·훈령	미충족	계정 삭제 API가 요청 본문의 userId만 확인할 뿐 실제 호출자가 해당 사용자 본인(또는 관리자)인지 서버에서 인증·검증하지 않는다. app/api/delete-account/route.ts: const { userId } = await request.json(); if (!userId) { return NextResponse.json({ error: "User ID is required" }, { status: 400 }); } // Supabase Admin API로 사용자 삭제 const { error } = await supabaseAdmin.auth.admin.deleteUser(userId);
업로드된 파일이 추측 가능한 공개 URL로 노출되지 않는다 S-upload-exposure · 필수	고시·훈령	판단불가	아바타 업로드 경로가 사용자ID+타임스탬프 조합으로 어느 정도 예측 불가능성이 있으나 버킷이 공개(getPublicUrl)로 설정되어 있어 추가 확인이 필요하다. components/ProfileEditModal.tsx: const fileName = `\${currentUser.id}-\${Date.now()}.\${fileExt}`; const filePath = `\${currentUser.id}/\${fileName}`;
비밀번호를 평문으로 저장하지 않는다 (해시 저장) S-password-storage · 필수	고시·훈령	충족	커뮤니티 게시물 비밀번호는 bcrypt로 해싱되어 저장되고 삭제 시 compare로 검증된다.



항목	법적 무게	판정	사유·근거
			<pre>app/actions/community.ts: const hashedPassword = await hash(password, 10); app/actions/community.ts: const isValid = await com pare(inputPassword, post.password);</pre>
학생 데이터가 수탁자(호스팅·DB 등) 외 독립 제3자에게 전송되지 않거나, 전송 시 법적 근거·고지가 있다 R-third-party · 필수 · L2	법률	판단불가	Google Analytics·애드센스 스크립트가 삽입되어 방문자 데이터가 구글로 전송되지만, 개인정보처리방침의 위탁업체 목록에는 Supabase만 명시되어 있어 고지 충분성을 사람이 확인해야 한다. <pre>app/layout.tsx: src="https://www.googletagmanager.co m/gtag/js?id=G-NNDKQ3G8J5"</pre> <pre>app/privacy/page.tsx: Supabase Inc.</stron g></pre>
입력이 검증 없이 HTML·쿼리로 실행되는 경로 (innerHTML·SQL 문자열 조합 등)가 없다 S-injection · L0	공식 권고	미충족	course.title 등 사용자/외부 데이터가 포함된 JSON을 이스케이프 없이 dangerouslySetInnerHTML로 스크립트 태그에 직접 주입하여 XSS 위험이 있다. <pre>app/courses/[id]/page.tsx: dangerouslySetInnerHT ML={{ _html: JSON.stringify(jsonLd) }}</pre> <pre>lib/db-api.ts: const safeSearch = filters.search.replace (/[,%]/g, ""); if (safeSearch) { query = query.or(` title.ilike.%\${s afeSearch}%,category.ilike.%\${safeSearch}%`); }</pre>
모든 리소스·전송이 https S-https · L0	고시·훈령	미충족	이미지 리소스 설정에 http 프로토콜 호스트가 명시적으로 허용되어 있다. <pre>next.config.ts: { protocol: 'http', hostname: 'openapi.s eoul.go.kr', port: "", pathname: '/*' }, // [추가] 서울시 이미지 (h ttp 가능성 있어 둘 다 추가)</pre> <pre>middleware.ts: const allowedOrigins = ['http://localhost: 3000', 'http://localhost:3100', 'http://woodongbae.xyz', 'htt p://www.woodongbae.xyz', 'https://woodongbae.xyz', 'http s://www.woodongbae.xyz'];</pre>
API 응답이 화면에 필요한 것보다 많은 개인정보 필드를 내려보내지 않는다 S-api-overfetch	공식 권고	미충족	게시글 목록 조회 시 select("*")로 비밀번호 해시 컬럼까지 포함해 전체 필드를 클라이언트에 내려보낸다. <pre>app/actions/community.ts: const { data: posts } = a wait supabase .from("posts") .select("*") .order("created_at", {</pre>



항목	법적 무게	판정	사유·근거
			<pre>ascending: false }) .limit(100); // 100개만 가져오기</pre> <pre>app/actions/community.ts: password: hashedPassword,</pre>
교사·관리자 기능이 하드코딩 비밀번호가 아닌 실제 권한 체계로 보호된다 S-teacher-gate	모범 사례	미충족	관리자 대시보드 페이지에 로그인/권한 확인 로직이 전혀 없어 URL만 알면 누구나 접근 가능하다. <pre>app/admin/page.tsx: export default async function AdminPage() { const supabase = await createClient(); const { count: courseCount } = await supabase.from('courses').select('*', { count: 'exact', head: true });</pre>
한도 소진·남용 공격 대비 (App Check·호출 제한 등 — DB·AI 호출 포함) S-abuse-limit	모범 사례	미충족	외부 공공데이터 API를 반복 호출하는 동기화 엔드포인트가 인증이나 호출 제한 없이 공개 GET으로 노출되어 있어 남용 시 비용/트래픽 소진 위험이 있다. <pre>app/api/sync/route.ts: export async function GET() { try { const apiKey = process.env.NEXT_PUBLIC_API_KEY;</pre>
쓰기 규칙에 크기·형식 검증 (도배 방지) S-write-guard	모범 사례	판단불가	쓰기 규칙(크기·형식 검증)이 정의된 supabase schema/migrations 파일이 이 묶음에 포함되어 있지 않아 확인할 수 없다.
운영 계정 2단계 인증 H-2fa	고시·훈령	판단불가	—
학교 정식 도입 시 학교운영위원회 심의를 거쳤는지 확인 H-school-approval	법률	판단불가	—

조건 미해당 항목 (자동 '해당없음' 처리 — 투명성 고지)

개인정보 수집 시 만 14세 미만 보호자 동의 안내·절차가 있다 — 적용 조건 "학생·학부모 개인정보를 수집한다"이 이 앱에 해당하지 않아 심사에서 제외됨

감정·고민 입력 기능이 있다면 위기 안내(교사·1388)가 있다 — 적용 조건 "학생이 직접 사용하는 화면이 있다"이 이 앱에 해당하지 않아 심사에서 제외됨



학생 데이터 파일(명단·성적 csv 등)이 저장소에 포함되지 않는다 — 적용 조건 "학생 실데이터(명단·성적 파일)를 다룬다"이 이 앱에 해당하지 않아 심사에서 제외됨

점수·완료·보상 값을 클라이언트가 임의로 쓸 수 없다 — 적용 조건 "평가·점수·랭킹·경쟁 기능이 있다"이 이 앱에 해당하지 않아 심사에서 제외됨

학생 A가 학생 B의 기록을 덮어쓰기·삭제·사칭할 수 없다 — 적용 조건 "학생이 직접 사용하는 화면이 있다"이 이 앱에 해당하지 않아 심사에서 제외됨

학생 입력이 외부 LLM으로 전송되면 고지 + "개인정보 입력 금지" 안내 — 적용 조건 "학생이 직접 사용하는 화면이 있다"이 이 앱에 해당하지 않아 심사에서 제외됨

민감정보(감정·건강·상담)를 익명·가명 처리 또는 기기 내 보관 — 적용 조건 "민감정보(건강·상담·성적 상세)를 다룬다"이 이 앱에 해당하지 않아 심사에서 제외됨

최소한의 개인정보만 수집 (닉네임 대체 가능한 것은 대체) — 적용 조건 "학생·학부모 개인정보를 수집한다"이 이 앱에 해당하지 않아 심사에서 제외됨

개인정보 처리방침(법정 고지 — 항목·목적·보관 기간·문의처 등)을 갖추고 수집 전에 알린다 — 적용 조건 "학생·학부모 개인정보를 수집한다"이 이 앱에 해당하지 않아 심사에서 제외됨

학교 정식 도입이면 국내 리전 저장, 개인 파일럿이면 해외 저장 사실을 안내한다 — 적용 조건 "학생·학부모 개인정보를 수집한다"이 이 앱에 해당하지 않아 심사에서 제외됨

학생 A의 데이터를 B·외부인이 볼 수 없는 구조 — 적용 조건 "학생이 직접 사용하는 화면이 있다"이 이 앱에 해당하지 않아 심사에서 제외됨

공용 기기에서 이전 사용자 정보가 남지 않는 처리 — 적용 조건 "학생이 직접 사용하는 화면이 있다"이 이 앱에 해당하지 않아 심사에서 제외됨

공개 화면(랭킹·결과 공유·프로젝터)에 실명·학번이 노출되지 않는다 — 적용 조건 "학생이 직접 사용하는 화면이 있다"이 이 앱에 해당하지 않아 심사에서 제외됨

AI 생성물에 AI 표시 — 적용 조건 "AI가 생성한 내용을 화면에 보여준다"이 이 앱에 해당하지 않아 심사에서 제외됨

AI 판정류에 "틀릴 수 있다" 고지 — 적용 조건 "AI가 생성한 내용을 화면에 보여준다"이 이 앱에 해당하지 않아 심사에서 제외됨



제외됨

정답·채점 기준이 클라이언트로 내려오지 않는다 — 적용 조건 "평가·점수·랭킹·경쟁 기능이 있다"이 이 앱에 해당하지 않아 심사에서 제외됨

교육적 적절성 — 발달단계 적합, 낙인·서열화 없음 — 적용 조건 "교과 학습을 목적으로 하는 콘텐츠다"이 이 앱에 해당하지 않아 심사에서 제외됨

명시한 성취기준과 활동 내용 부합 — 적용 조건 "교과 학습을 목적으로 하는 콘텐츠다"이 이 앱에 해당하지 않아 심사에서 제외됨

수업 맥락에서 실사용 가능 — 적용 조건 "교과 학습을 목적으로 하는 콘텐츠다"이 이 앱에 해당하지 않아 심사에서 제외됨

활동 종료 후 데이터 파기 계획 확인 — 적용 조건 "학생·학부모 개인정보를 수집한다"이 이 앱에 해당하지 않아 심사에서 제외됨

학생 1명 단위 삭제 수단 + 파생 데이터(랭킹 등) 함께 파기 — 적용 조건 "학생·학부모 개인정보를 수집한다"이 이 앱에 해당하지 않아 심사에서 제외됨

개인정보 유출 시 72시간 내 신고·통지 대응 절차를 알고 있다 — 적용 조건 "학생·학부모 개인정보를 수집한다"이 이 앱에 해당하지 않아 심사에서 제외됨



EDUSAFETY REVIEW RECORD

에듀 세이프 심사 기록 확인

필수 조건 미충족

에듀 세이프 심사 절차로 이 고정 제출물을 검토한 기록입니다.

심사 판정 · 루브릭 core-1



필수 조건 미충족

반드시 수정 2건 · 수정 후
재심사 필요
DevYonghunT/WooDongBae ·
Git commit ca6c5e6629ec

문서 식별·서명 연계 정보

EAS UID·서명 없음

문서 기준	Git commit ca6c5e6629ec338d0055aef4bef5c2d7 f0ea92b7
서명 상태	이 보고서에는 EAS UID와 전자서명이 생성되지 않음
연계 규격	EAS Offchain v2 · EIP-712 지원
연계 기준	Base Sepolia · Chain ID 84532

이 마크는 에듀 세이프 형식으로 생성된 심사 기록과 고정 제출물의 판정 요약을 표시합니다. EAS UID가 함께 표시된 경우에만 전자서명
검증이 가능하며, 페이지 상단 UID는 같은 증명을 가리키는 참조값이지 각 페이지의 개별 서명이 아닙니다. EAS Offchain v2는 온체인
거래나 정부·공공기관 인증을 의미하지 않습니다.

심사 확인

AI 판정은 초안이며, 이 보고서의 최종 판정 권한과 책임은 심사자에게 있습니다 (원칙 4).

심사자 성명: _____ 소속: _____ 서명: _____